
Form 8 of 8: Software and Engineering

Who fills this in: engineering lead or lead developer. **Skip this form if you do not build software.** **Time:** about 15 minutes. **"I do not know" is a real answer.**

Company: _____ Your name: _____ Date: _____

1. What do you build, and who uses it?

2. Where does the code live?

☐ GitHub ☐ GitLab ☐ Bitbucket ☐ Azure DevOps ☐ Self hosted ☐ Other: _____

3. Are any repositories public?

☐ Yes, on purpose ☐ Not sure ☐ All private

4. Does code review happen before merge? Always, or when there is time?

☐ Always required ☐ Usually ☐ Rarely

5. How does code get to production? Who can deploy?

6. Where do secrets and API keys live?

☐ Secret manager ☐ Environment variables ☐ Config files in the repo ☐ Mixed ☐ Not sure

7. Has a secret ever been committed to a repository?

☐ Yes, and rotated ☐ Yes, not sure if rotated ☐ No ☐ Probably

8. Do you scan dependencies for known vulnerabilities?

☐ Yes, automated ☐ Occasionally ☐ No

9. Do developers have access to production data? Do you use real data in test environments?

Prod access: ☐ Yes ☐ No Real data in test: ☐ Yes ☐ No ☐ Sometimes

10. Has the product ever had a penetration test? When, and can we see the report?

11. Do you log what happens in production? Would you know if someone got in?

☐ Good logging and alerts ☐ Logs exist, nobody watches ☐ Minimal

12. Do you use AI coding tools or paste code into AI services?

☐ Yes, approved tools ☐ Yes, whatever people choose ☐ No ☐ Not sure

What part of the system would you least like an attacker to find?
